

 ENGINEERING	Personnel procedures	PGP
Servizio Protezione Dati personali	<i>Policy Gestione Data Breach</i>	

DATA BREACH MANAGEMENT POLICY

Written by:	Personal Data Protection Service
Verified by:	Directorate General Human Resources & Organization (HRO)
Approved by:	C. Biestro
Authorised by:	P. Pandozy
Validity date:	09/03/2020
Version no .:	1.0
Pages:	11
Distribution:	Company Intranet Site

File name: RGP03_0_Policy_Gestione_Data_Breach 1.0

Caution

This document is available in original copy on the corporate network server.
Any hard copy is deemed to be an unverified working copy.
It is the responsibility of those who use unverified copies to check their updating level.

PGP		Personnel procedures
Servizio Protezione Dati personali	<i>Policy Gestione Data Breach</i>	

SUMMARY

FIELD OF APPLICATION	4
PURPOSE	4
1.1 REFERENCE DOCUMENTATION	4
DEFINITIONS	4
2 OBLIGATIONS RESULTING FROM THE OCCURRENCE OF A DATA BREACH.....	6
2.1 REPORTING CHANNELS	6
2.2 DETERMINATION OF THE SERIOUSNESS OF THE VIOLATION	7
2.3 EVENT REGISTRATION	7
2.4 NOTIFICATION TO THE SUPERVISORY AUTHORITY	7
2.5 COMMUNICATION OF THE VIOLATION TO THE DATA SUBJECT.....	10
2.6 POST BREACH ANALYSIS.....	11

PGP		Personnel procedures
Servizio Protezione Dati personali		<i>Policy Gestione Data Breach</i>

VERSION UPDATES

Version	Date	Reason	Changes
1.0	09/03/2020	First issue	Definition of policy

PGP		Personnel procedures
Servizio Protezione Dati personali		<i>Policy Gestione Data Breach</i>

FIELD OF APPLICATION

This policy applies to all Companies of the Engineering Group (**TB00_0 Procedura Aziende**).

For the purposes of this policy, the Company is intended as the Data Controller, unless otherwise indicated below.

PURPOSE

The General Data Protection Regulation (GDPR) requires both the Data Controller and the Data Processor to have adequate technical and organizational measures to ensure a level of security proportionate to the risk to which the personal data processed are exposed.

Consequently, it is necessary to put in place technological and organizational measures in order to guarantee the security of the processing, as well as procedures suitable for intercepting and promptly managing any violations of personal data. This Policy describes the obligations which all Group Companies, as Data Controllers (or Data Processors) must comply with when managing personal data breaches (hereinafter also referred to as "Data Breach" in the singular) according to the applicable legislation. For the organizational, process and instrumental methods adopted for the management of all security incidents, please refer to the specific Company procedures.

By personal data breach or Data Breach we mean a **security breach** that accidentally or illegally involves the destruction, loss (of documents, including paper, or PCs, mobile phones, backup discs, etc.), modification, unauthorized disclosure or access to Personal Data transmitted, stored or otherwise processed.

While all personal data breaches are security incidents, not all security incidents are necessarily personal data breaches.

Depending on the circumstances in which it occurs, the violation may or may not require notification to the Supervisory Authority and communication to the natural persons involved.

In any case, the Data Controller is obliged to record all data breaches, in order to demonstrate the assumption of responsibility to the Supervisory Authority, which could also request to access these records.

Unless otherwise provided in this document, all terms reported with a capital letter refer to the definitions contained in the GDPR and reported in the table TB02_MSGTD_0_Glossario Privacy.

1.1 REFERENCE DOCUMENTATION

- General Data Protection Regulation (EU) 2016/679 (hereinafter referred to as GDPR);
- Articles 33 and 34 GDPR - Notification of a personal data breach to the Supervisory Authority;
- Guidelines on the notification of personal data breaches pursuant to the GDPR (17 / EN WP 250);
- [Privacy PGT01_0_Gestione Privacy GDPR](#);
- ENISA, Recommendations for a methodology of the assessment of severity of personal data breaches, Working Document, v1.0, December 2013.

DEFINITIONS

❑ False positive

A security incident that does not involve the involvement of personal data

❑ Classification of data breaches

 ENGINEERING	Document for internal use - Reproduction prohibited RGP03_0_Policy_Gestione_Data_Breach 1.0	4/11
--	--	------

PGP		Personnel procedures
Servizio Protezione Dati personali		<i>Policy Gestione Data Breach</i>

Breaches can be classified according to the following three well-known principles in the field of information security:

- "Breach of confidentiality", in the event of disclosure of personal data or unauthorized or accidental access to the same;
- "Breach of integrity", in the event of unauthorized or accidental modification of personal data;
- "Availability violation", in the event of accidental or unauthorized loss, access or destruction of personal data.

Depending on the case, a breach may simultaneously affect the confidentiality, integrity and availability of personal data, as well as any combination thereof.

While determining whether there has been a breach of confidentiality or integrity is relatively obvious, it may be less obvious to determine whether there has been a breach of availability.

By availability we mean the guarantee of timely and reliable access and use of the information, or the characteristics of being accessible and usable on request made by an authorized person.

A data breach will always be considered an availability breach if there has been permanent loss or destruction of personal data.

A security incident that results in the unavailability of personal data for a certain period of time constitutes a data breach, as the lack of access to the data can have a significant impact on the rights and freedoms of individuals. It should be noted that the unavailability of personal data due to a scheduled maintenance intervention on the system does not constitute a "security breach" pursuant to article 4, point 12 of the GDPR, always and only if previously made known to the data subjects.

Confidentiality means the guarantee that the data will not be made known to unauthorized persons

Integrity means the guarantee that the data or media have not been altered.

PGP		Personnel procedures
Servizio Protezione Dati personali		<i>Policy Gestione Data Breach</i>

2 OBLIGATIONS RESULTING FROM THE OCCURRENCE OF A DATA BREACH

2.1 REPORTING CHANNELS

Reports of abnormal events can

- come from the Company's staff;
- be forwarded by the DPO, if any;
- come from external channels, such as, for example, the online form on the site www.eng.it (if any), or the pages of the Social Networks (Facebook, Twitter), or even the information on the Web; the report, moreover, can also be received from the Managers, or from the Data Controller, whose data are processed;

finally, each data subject can report, even in the case of mere suspicion, any abusive or fraudulent use of their personal data, requesting an appropriate verification from the Company.

The reports, sent to any person/function, must be promptly communicated to their hierarchical manager (Privacy Contact), by sending an email with the subject "Suspected violation of personal data", with a brief description of the suspected event.

Consequently, the Privacy Contact must promptly report the incident to the competent structures, alternatively:

- by sending the report via e-mail to the following addresses: dpo.privacy@eng.it; security@eng.it, csirt.eng@cybertech.eu and to their own Privacy Managers (Service Project Privacy Manager) and Data Manager;
- by entering the report in the appropriate Trouble Ticketing system in use, through its competent perimeters.

Regardless of the communication channel chosen, the report must necessarily be accompanied by the form MD01_RGP03_0_Scheda_Evento_Data_Breach & Assessment duly completed, based on the information available during the investigation.

If from the examination of the Data_Breach & Assessment it clearly emerges that the event does not in any way constitute a personal data breach (so-called "False positive", such as, for example, the unavailability of a server on which, following an investigation, there were no personal data) the event is in any case inserted by the Dpo in the appropriate register and the report is closed, without prejudice to any other obligations related to security incidents prescribed by the Company.

If, on the other hand, from the first analysis it emerges that it is actually a violation of personal data, the Privacy Manager in agreement with the Dpo, based on the role assumed by the Company in the processing of the data to which the violation refers (Data Controller or Data Processor), will carry out the following actions:

- if it has the role of Data Processor: will promptly notify the Data Controller according to the terms and methods provided for in the processing agreement, providing all the information at its disposal so that it can fulfill the obligations established by the legislation in Articles. 33 and 34 GDPR.
The Data Processor will assist the Data Controller by initiating a preliminary analysis aimed at collecting data concerning the anomaly, by filling in the form MD02_RGP03_0_Modello_comunicazione_Data_Breach to the Data Controller or further documentation provided by the Data Controller;
- If it has the role of Data Controller: it will involve all the Company Functions that could be impacted and/or involved in the violation, for example, the IT/Security function, the head of internal information systems, the Commercial Director and Technical Director, and where necessary, also the Legal Office, the Head of General Human Resources & Organization, Top Management, etc. A multifunctional structure is thus formed for the management of the violation (hereinafter referred to for simplicity as the Data Breach Assessment Unit ("DBAU")),

	Document for internal use - Reproduction prohibited RGP03_0_Policy_Gestione_Data_Breach 1.0	6/11
---	--	------

PGP		Personnel procedures
Servizio Protezione Dati personali		<i>Policy Gestione Data Breach</i>

In both cases, the DBAU performs an assessment of the severity of the event, and on the basis of it takes the consequent actions required by the legislation (notification to the supervisory authority; notification to the data subjects).

It also promptly defines the security and mitigation measures to be taken in order to diminish the effects of the violation and/or prevent its perpetration or repetition.

2.2 DETERMINATION OF THE SEVERITY OF THE VIOLATION

The severity of the data breach is automatically determined by filling in the Model MD01_RGP03_0_Scheda_Evento_Data_Breach & Assessment.

The calculation algorithm implemented in the model is based on the methodology described in the ENISA document: Recommendations for a methodology of the assessment of severity of personal data breaches, and takes into consideration the following aspects of a data breach:

- the context of the processing (DPC);
- the possibility of identification (EI) of the data subject (to whom the data impacted by the violation refer);
- the circumstances of the breach (CB), or the characteristics of the event, or of the violation.

To each of these three parameters, on the basis of the specific characteristics assumed in the specific case, a score is assigned.

Finally, the scores of the individual parameters are calculated together in order to determinate the overall score, i.e. the degree of severity, or severity of the data breach (SE), using the following formula:

$$SE = DPC \times EI + CB$$

2.3 EVENT REGISTRATION

The Data Breach Register is kept by the DPO under the responsibility of the Data Controller.

Each Group company must ensure that measures are promptly taken in order to minimize the negative consequences of the violation.

Once the violation has been classified, DBAU then evaluates the actions to be taken and initiates, if necessary, the notification to the Supervisory Authority and the communication to the data subjects, verifying and validating the documentation received from the previous phases of the adopted process.

The notification to the Supervisory Authority and any communication to the Data Subjects must be made in the event that the analysis of the violation reveals a risk for the rights and freedoms of the Data Subject.

2.4 NOTIFICATION TO THE SUPERVISORY AUTHORITY

The notification of the violation to the competent Supervisory Authority is made by the DPO and/or DBAU and must be made, without undue delay and, where possible, within 72 hours from the moment in which it became known, unless it is unlikely that the violation of personal data presents a risk for the rights and freedoms of Data Subjects and therefore has been classified by the same as "LOW".

If the notification to the Supervisory Authority is not made within 72 hours, it must be accompanied by the reasons for the delay.

The notification to the Supervisory Authority must describe, where possible

- the nature of the Personal Data Breach,

	Document for internal use - Reproduction prohibited RGP03_0_Policy_Gestione_Data_Breach 1.0	7/11
---	--	------

PGP		Personnel procedures
Servizio Protezione Dati personali		<i>Policy Gestione Data Breach</i>

- the categories and approximate number of Data Subjects involved,
- the categories and approximate number of records of the Personal Data in question;
- The name and contact details of the DPO or other contact point from which to obtain more information;
- the possible consequences of the Personal Data Breach;
- the measures adopted or proposed by the Company to remedy the Personal Data Violation and also, if necessary, to mitigate its possible negative effects.

If it is not possible to provide all the relevant information when the notification is made, the information's can be provided in subsequent stages without further unjustified delay, and in any case no later than 48 hours more than the time of reporting.

The model is usually available on the website of the Supervisory Authority.

Indicated below, as an example, are some situations that require notification to the Supervisory Authority and/or data subjects.

Example	Notification to the supervisory authority?	Communication to the Data subject?	Notes / recommendations
Personal data stolen from a website managed by a subject through a cyber-attack.	YES	YES	Notification to the subject is only necessary if the risk of harm is high
A hospital's medical records are unavailable for a period of 30 hours due to a cyber-attack.	Yes, the hospital is required to notify as there may be a high risk to the health and privacy of patients.	Yes, inform the data subjects involved.	
A data controller manages an online service. Following a cyber-attack against this service, the personal data of natural persons are collected. The controller has customers in only one European Member State.	Yes, report the event to the Supervisory Authority if there are likely consequences for natural persons.	Yes, report the event to data subjects depending on the nature of the personal data in question and whether the seriousness of the likely consequences for such subjects is high.	
A controller operates an online marketplace and has customers in multiple European Member States. This market is under a cyber-attack which causes usernames, passwords and purchase history to be posted online by the attacker.	Yes, report the event to the lead supervisory authority if the violation concerns cross-border processing.	Yes, as the breach could carry a high risk.	The controller should take measures, such as forcing the password reset of the affected accounts, and other measures to mitigate the risk. The controller should also consider any other notification obligations, for example under the NIS Directive, in the case of a digital service provider.

PGP		Personnel procedures
Servizio Protezione Dati personali	<i>Policy Gestione Data Breach</i>	

A data controller suffers a ransomware attack that causes all data to be encrypted. There are no backups and the data cannot be restored. During the investigation, it becomes apparent that the only function of the ransomware was data encryption and that there was no other malware present in the system.	Yes, please report to the supervisory authority, if there are possible consequences for data subjects that cause the loss of availability.	Yes, report to Data subjects, depending on the nature of the personal data concerned and the possible effect of the lack of data availability, as well as other possible consequences.	If a backup was available and the data could have been restored in reasonable time, it would not have been necessary to report the violation to the supervisory authority or to the data subjects, as there would have been no permanent loss of availability or confidentiality. However, if the supervisory authority had become aware of the incident by other means, it could have considered carrying out an investigation in order to assess compliance with the broader safety requirements of Article 32.
A website hosting company acting as the Data Processor detects an error in the code that checks the user's authorization. Due to this defect, any user can access the account details of any other user.	As a data processor, the website hosting company must notify the affected customers (the controllers) without undue delay. Assuming that the website hosting company has conducted its own investigation, the data controllers concerned should be reasonably certain that they have suffered a breach and are therefore likely to be considered "aware" of the breach by the time they are notified by the hosting company (the data processor). The controller must then notify the supervisory authority.	If there is no probable high risk to data subjects, it is not necessary to make a communication to such persons.	The website hosting company (data processor) has to consider any other notification obligations (e.g. under the NIS Directive, being a digital service provider). If there is no evidence that this vulnerability is exploited by one of its controllers, the breach may not be subject to the obligation to notify, however it could be a breach to be registered or a sign of non-compliance with Article 32
A direct marketing email is sent to recipients in the "to:" or "cc:" fields, thus allowing each recipient to see the email address of other recipients.	Yes, notification to the supervisory authority may be mandatory if a large number of people are affected, if sensitive data is revealed (for example a psychotherapist's mailing list) or if other factors present high risks (for example, the message of email contains the initial passwords).	Yes, report the event to the natural persons involved based on the extent and type of personal data involved and the severity of the possible consequences.	Notification may not be necessary if no sensitive data is disclosed and if only a limited number of e-mail addresses are disclosed

PGP		Personnel procedures
Servizio Protezione Dati personali		<i>Policy Gestione Data Breach</i>

However, cases such as the following do not require notification:

Example	Notification to the supervisory authority?	Communication to the Data Subject?	Notes / recommendations
Archive containing encrypted personal data saved on a cd. The cd is stolen.	NO	NO	The data is encrypted using an algorithm. Therefore, are indecipherable.
A data controller made a backup of an encrypted personal data archive on a USB key. The key is stolen during a break-in.	NO	NO	As long as the data is encrypted with an advanced algorithm, backups of the data exist, the unique key is not compromised, and the data can be recovered in time, this may not be a breach to report. However, if the key is subsequently compromised, notification is required.
A brief power outage of several minutes at a controller's call center prevents customers from calling the controller and accessing their records.	NO	NO	This is not a notifiable violation, but still constitutes a recordable incident under Article 33 (5). The data controller must keep adequate records in this regard.

2.5 COMMUNICATION OF THE VIOLATION TO THE DATA SUBJECT

The DPO and/or the competent company function must inform the data subjects of the anomalous event, in all cases in which, pursuant to art. 33-34 GDPR assesses that the violation presents high risks for the rights and freedoms of individuals.

The communication must be addressed to the data subject without undue delay after the discovery of the event and evaluation of the violation, through the communication channel deemed most suitable; it must be carried out by the competent corporate function and must be intelligible, concise, transparent, and easily accessible; the language used must be simple and clear, adopting, if possible, the same language spoken by the data subject. Methods of communication applied are those considered most suitable by the competent company function, possibly supported by the Communication and Marketing Department.

Data Breach communication to the Data Subject must contain the following information:

- date and time of the violation, even if only alleged, and date and time in which it became known;
- the nature of the Personal Data Breach;
- the name and contact details of the DPO, if any, or of another contact point from which to obtain more information;
- the likely consequences of the Personal Data Breach;
- a description of the measures adopted or proposed to be adopted by the Company to remedy the Personal Data Breach and also, if necessary, to mitigate any possible negative effects.

Notification to the data subject is not required if one of the following conditions is met:

- adequate technical and organizational protection measures have been applied to the Personal Data subject to the violation, in particular those intended to make the Personal Data incomprehensible to anyone not authorized to access it, such as encryption; except in cases where the breach of security has resulted in the destruction or loss of the Personal Data of the Data Subjects;
- measures were subsequently adopted to avoid the occurrence of a high risk for the rights and freedoms of individuals - in this case it is necessary to document the measures in the violation sheet;

	Document for internal use - Reproduction prohibited RGP03_0_Policy_Gestione_Data_Breach 1.0	10/11
---	--	-------

PGP		Personnel procedures
Servizio Protezione Dati personali	<i>Policy Gestione Data Breach</i>	

- such communication would require disproportionate efforts. In this case, instead, a public communication or a similar measure is carried out, through which the Data Subjects are informed with similar effectiveness.

2.6 POST BREACH ANALYSIS

In order to verify the effectiveness and efficiency of the actions taken during the management of data breach and to identify possible areas for improvement, it is recommended to collect all the "evidence", to carry out a post-analysis accident.

This activity requires the involvement of the corporate IT/Security functions, with possible support from other functional areas.